CYPHER GROUP INC. · SIMULATED CASE STUDY

Cypher Group Inc. — Startup Security Policy Pack

Field	Value
Document set	CGI-POL-001 to CGI-POL-005
Pack version	1.0
Classification of this document	Internal
Prepared by	O.S, GRC Analyst (engaged)
Approved by	Jerry Gold, Chief Executive Officer
Approval date	01 September 2026
Effective date	15 September 2026
Next scheduled review	01 September 2027

> **All data in this pack is simulated.** Cypher Group Inc. is a simulated company. This pack demonstrates policy development, framework mapping and policy governance.

About Cypher Group Inc. (the scenario)

Cypher Group Inc. is a 50-person B2B SaaS company selling a project-management platform to approximately 200 small and medium-sized business customers.

Attribute	Detail
Employees	50
Product	B2B SaaS project-management platform
Customers	~200 SMBs
Hosting	CloudCo
Source code	CodeCo
Internal communications	ChatCo
Email and documents	OfficeCo
Payments	PaymentsCo (Cypher stores payment metadata only; card numbers are held by PaymentsCo)
Data handled	Customer account data, payment metadata, internal documents, limited PII
Security maturity	Early-stage; no formal GRC programme prior to this pack

The business problem this pack solves. Cypher Group has begun receiving security questionnaires from prospective customers. The first question on almost every one of them is *"Do you maintain a documented information security policy, approved by management and reviewed at least annually?"* Until this pack was approved, the answer was **No**. Three deals were held at security review as a result. This pack changes the answer to **Yes** and provides the evidence.

How to read this pack — the document hierarchy

Cypher Group uses a four-level documentation hierarchy. Knowing which level a statement belongs to is what keeps the pack maintainable.

Level	Answers	Approved by	Changes	Example from this pack
Policy	What and why	CEO or CTO	Annually	"Access shall be granted on the principle of least privilege."
Standard	The specific mandatory requirement	CTO	Occasionally	"Passwords shall be a minimum of 14 characters."
Procedure	Step-by-step how	Process owner	Frequently	"To offboard a user: 1. People Ops raises ticket..."

Level	Answers	Approved by	Changes	Example from this pack
Guideline	Recommended, not mandatory	CTO	Freely	"Consider enabling a passkey on personal accounts too."

This pack contains **policies with embedded standards**. Procedures are referenced but maintained separately in the Cypher Group internal wiki.

Pack contents and document control register

Doc ID	Policy	Version	Owner (role)	Approver	Approval date	Effective date	Next review	Sign-off required
CGI-POL-001	Acceptable Use Policy	1.0	Head of People and Operations	CEO	2026-09-01	2026-09-15	2027-09-01	Yes, all staff
CGI-POL-002	Password and Multi-Factor Authentication Policy	1.0	Chief Technology Officer	CEO	2026-09-01	2026-09-15	2027-09-01	Yes, all staff
CGI-POL-003	Onboarding and Offboarding Access Control Policy	1.0	Chief Technology Officer	CEO	2026-09-01	2026-09-15	2027-09-01	No, managers only
CGI-POL-004	Data Classification Policy	1.0	Chief Technology Officer	CEO	2026-09-01	2026-09-15	2027-09-01	Yes, all staff
CGI-POL-005	Incident Reporting Policy	1.0	Chief Technology Officer	CEO	2026-09-01	2026-09-15	2027-09-01	Yes, all staff

Named roles referenced throughout this pack (simulated)

Role	Name (simulated)	Policy responsibilities
Chief Executive Officer	Jerry Gold	Approves the pack; accountable for the security programme
Chief Technology Officer	Priya Raman	Owns technical policies; acts as Incident Commander; approves exceptions
Head of People and Operations	Sofia Lindqvist	Owns the AUP; runs sign-off tracking; triggers joiner and leaver events
IT Operations Manager	Tomas Whitfield	Executes provisioning and deprovisioning; runs access reviews
Head of Customer Success	Amara Boateng	Data owner for customer account data
Finance Manager	Jonas Keller	Data owner for payment metadata and financial records

---

CGI-POL-001 — Acceptable Use Policy

Field	Value
Document ID	CGI-POL-001
Version	1.0
Classification	Internal
Policy owner	Sofia Lindqvist, Head of People and Operations
Approved by	Jerry Gold, Chief Executive Officer
Approval date	01 September 2026
Effective date	15 September 2026
Review cadence	Annually, or upon significant change
Next review due	01 September 2027
Employee sign-off	Required before system access is granted, and annually thereafter

Version history

Version	Date	Author	Summary of change	Approved by
1.0	2026-09-01	O.S	Initial issue	Jerry Gold

1. Purpose

This policy sets out how Cypher Group Inc. systems, devices, accounts and information may and may not be used. It exists to protect customer data, company information and Cypher Group's ability to operate, and to make clear to every individual what is expected of them so that nobody has to guess.

This policy also serves as the formal notice to all personnel that use of Cypher Group systems is monitored.

2. Scope

This policy applies to:

- All employees, directors, contractors, consultants, interns and temporary staff of Cypher Group Inc., referred to collectively as "personnel".
- All Cypher Group accounts, including OfficeCo, ChatCo, CodeCo, CloudCo, the PaymentsCo dashboard and any other system holding Cypher Group information.
- All devices used to access Cypher Group information, whether company-owned or personally owned.
- All Cypher Group information in any form, including electronic files, printed material and verbal communication.

Exclusions. This policy does not govern the personal use of personal devices where no Cypher Group information or account is involved.

3. Roles and responsibilities

Role	Responsibility
All personnel	Read, sign and comply with this policy; report suspected violations
Line managers	Ensure their reports have signed the policy; reinforce it in practice
Head of People and Operations	Own the policy; distribute it; track sign-off; include it in onboarding
Chief Technology Officer	Approve exceptions; provide the technical controls that enforce this policy
IT Operations Manager	Configure and maintain the enforcing technical controls

4. Policy statements

4.1 General use

4.1.1 Personnel **shall** use Cypher Group systems and information primarily for legitimate business purposes.

4.1.2 Limited, reasonable personal use of email, ChatCo and internet access **is permitted**, provided it does not interfere with work, consume significant resources, or breach any statement in this policy.

4.1.3 Personnel **shall not** assume privacy in any material created, stored or transmitted on Cypher Group systems, including material marked personal.

4.2 Prohibited activities

4.2.1 Personnel **shall not** use Cypher Group systems to access, store, create or transmit material that is unlawful, harassing, discriminatory, defamatory or obscene.

4.2.2 Personnel **shall not** attempt to gain access to any system, account or data for which they have not been granted authorisation, including by using another person's credentials.

4.2.3 Personnel **shall not** intentionally circumvent, disable or degrade any security control, including endpoint protection, disk encryption, logging or multi-factor authentication.

4.2.4 Personnel **shall not** use Cypher Group systems, information or customer relationships to operate a personal business or a competing venture.

4.2.5 Personnel **shall not** connect any device to the Cypher Group production environment other than a managed device meeting the requirements in section 4.4.

4.3 Credentials and accounts

4.3.1 Personnel **shall not** share their account credentials with any other person, including colleagues, contractors and line managers.

4.3.2 Personnel **shall** store all work credentials in the Cypher Group-provided password manager and **shall not** store credentials in browsers, spreadsheets, notes applications, ChatCo messages or source code.

4.3.3 Detailed authentication requirements are set out in **CGI-POL-002 Password and Multi-Factor Authentication Policy**.

4.4 Devices, including personally owned devices

4.4.1 Any device used to access Cypher Group email, ChatCo, documents or code **shall** have full-disk encryption enabled.

4.4.2 Any such device **shall** lock automatically after no more than 10 minutes of inactivity and require authentication to unlock.

4.4.3 Operating system and browser security updates **shall** be applied within 14 calendar days of release.

4.4.4 Personnel **shall not** access Cypher Group information from a device that has been jailbroken, rooted or otherwise modified to bypass its manufacturer security controls.

4.4.5 Personnel **shall not** permit family members or any other individual to use a device while a Cypher Group account is signed in.

4.4.6 Personnel **shall** report a lost or stolen device in accordance with **CGI-POL-005 Incident Reporting Policy** immediately and in any case within one hour of becoming aware.

4.5 Use of artificial intelligence tools

4.5.1 Personnel **shall** use only AI tools appearing on the Cypher Group approved AI tools list, maintained by the CTO in the internal wiki.

4.5.2 Personnel **shall not** enter information classified **Confidential** or **Restricted** into any AI tool that is not on the approved list. This expressly includes customer account data, customer personal data, payment metadata, credentials, unreleased product plans and proprietary source code.

4.5.3 Personnel **shall** treat AI-generated output as unverified. Output **shall not** be committed to production code, sent to a customer or published without human review by a competent person.

4.5.4 Requests to add a tool to the approved list **shall** be submitted to the CTO, who will assess the vendor's data handling, retention and training practices before approval.

4.6 Software, services and shadow IT

4.6.1 Personnel **shall not** procure, sign up for or begin using any third-party service that will store, process or transmit Cypher Group information without prior approval from the CTO.

4.6.2 Personnel **shall not** install unlicensed software, or software from an untrusted source, on any device used for Cypher Group work.

4.6.3 Personnel **shall** report any pre-existing unapproved service in use to the CTO without fear of penalty, so that it can be assessed and either approved or replaced.

4.7 Communications conduct

4.7.1 Personnel **shall** exercise care when addressing email and ChatCo messages containing Confidential or Restricted information, and **shall** verify recipients before sending.

4.7.2 Personnel **shall not** discuss Cypher Group customers, incidents, unreleased features or internal disputes on public forums, social media or personal messaging applications.

4.7.3 Personnel **shall** forward suspected phishing messages to the security reporting channel and **shall not** interact with them.

4.8 Removable media and printing

4.8.1 Personnel **shall not** copy Confidential or Restricted information onto removable media such as USB drives without prior written approval from the CTO.

4.8.2 Printed material containing Confidential or Restricted information **shall not** be left unattended and **shall** be destroyed by cross-cut shredding when no longer required.

4.9 Physical security of devices

4.9.1 Personnel **shall not** leave devices unattended in public spaces, including cafes, co-working areas and public transport.

4.9.2 Personnel **shall not** place devices containing Cypher Group information into checked baggage.

4.9.3 Devices **shall** be locked whenever the user steps away from them, including at home.

4.10 Monitoring notice

4.10.1 Cypher Group **monitors** the use of its systems for security, availability and compliance purposes. Monitoring includes authentication logs, cloud infrastructure activity logs, endpoint security telemetry, and email and file access metadata.

4.10.2 Monitoring is limited to what is necessary and proportionate for those purposes. Cypher Group **does not** routinely read the content of personal messages. Content **may** be accessed where there is a documented security or legal requirement, approved by the CEO.

4.10.3 By signing this policy, personnel acknowledge that this monitoring occurs.

4.11 Return of assets

4.11.1 On termination of employment or engagement, personnel **shall** return all Cypher Group devices, access cards and printed material within five business days.

4.11.2 Personnel **shall not** retain, copy or transfer any Cypher Group information to a personal account, device or storage service at any time, including in anticipation of departure.

5. Enforcement

5.1 Violations of this policy may result in suspension of system access, formal disciplinary action up to and including termination of employment or contract, and, where the conduct is unlawful, referral to law enforcement.

5.2 Access suspension pending investigation is a protective measure and is not in itself a disciplinary sanction.

5.3 Personnel who report their own accidental violation promptly and in good faith will be treated as having acted responsibly. Cypher Group prioritises rapid reporting over blame, in line with **CGI-POL-005**.

5.4 **Exceptions.** Any requirement in this policy may be excepted only by written approval of the CTO, recorded in the Cypher Group Exception Register with a business justification, a compensating control, a named accepting owner and an expiry date not exceeding 12 months.

6. Review cadence

6.1 This policy **shall** be reviewed at least annually by the policy owner, and additionally upon any significant change to Cypher Group's systems, size, customer commitments or regulatory obligations.

6.2 All personnel **shall** re-acknowledge this policy annually. Sign-off is tracked in the Employee Policy Sign-off and Training Tracker.

7. Related documents

- CGI-POL-002 Password and Multi-Factor Authentication Policy
- CGI-POL-003 Onboarding and Offboarding Access Control Policy
- CGI-POL-004 Data Classification Policy
- CGI-POL-005 Incident Reporting Policy

8. Framework mapping

Policy section	ISO/IEC 27001:2022 Annex A	NIST CSF 2.0
4.1 General use	A.5.10	GV.PO-01
4.2 Prohibited activities	A.5.10, A.8.1	GV.PO-01, PR.AA-05
4.3 Credentials	A.5.17	PR.AA-01

Policy section	ISO/IEC 27001:2022 Annex A	NIST CSF 2.0
4.4 Devices and BYOD	A.6.7, A.8.1	PR.PS-01, PR.AA-05
4.5 AI tools	A.5.23, A.8.12	GV.PO-01, PR.DS-01
4.6 Shadow IT	A.5.23, A.8.19	ID.AM-02, GV.SC-04
4.7 Communications	A.5.14, A.6.3	PR.AT-01
4.8 Removable media	A.7.10, A.8.10	PR.DS-01
4.9 Physical security	A.7.7, A.7.9	PR.AA-06
4.10 Monitoring notice	A.8.16, A.5.34	DE.CM-03, GV.PO-02
4.11 Return of assets	A.5.11	PR.AA-05

9. Definitions

Term	Definition
Personnel	Any individual working for or on behalf of Cypher Group, whatever their contract type
Managed device	A device configured to Cypher Group standards with encryption, screen lock and endpoint protection
Shadow IT	Any third-party service used for company work that has not been approved
Approved AI tools list	The register of AI services personnel may use, maintained by the CTO
Exception	A documented, time-limited, approved deviation from a policy requirement

10. Acknowledgement

> I confirm that I have read and understood the Cypher Group Inc. Acceptable Use Policy (CGI-POL-001 v1.0), that I understand my use of company systems is monitored as described in section 4.10, and that I agree to comply with it.
>
> Name: _____ Employee ID: _____
>
> Signature: _____ Date: _____

CGI-POL-002 — Password and Multi-Factor Authentication Policy

Field	Value
Document ID	CGI-POL-002
Version	1.0
Classification	Internal
Policy owner	Priya Raman, Chief Technology Officer
Approved by	Jerry Gold, Chief Executive Officer
Approval date	01 September 2026
Effective date	15 September 2026
Review cadence	Annually, or upon significant change
Next review due	01 September 2027
Employee sign-off	Required

Version history

Version	Date	Author	Summary of change	Approved by
1.0	2026-09-01	O.S	Initial issue. Aligned to NIST SP 800-63B-4.	Jerry Gold

1. Purpose

Stolen and reused passwords are the most common way attackers gain access to a company of Cypher Group's size. This policy sets the authentication standards that make a stolen password insufficient on its own, and defines how credentials must be created, stored and protected.

The requirements in this policy are aligned to **NIST SP 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management** (the current revision; the earlier SP 800-63B has been withdrawn). Cypher Group has adopted its two most significant modern positions deliberately: **length is prioritised over character complexity**, and **passwords are not rotated on a routine schedule**, because forced rotation reliably produces weaker, more predictable passwords.

2. Scope

This policy applies to all personnel and to all Cypher Group accounts, including OfficeCo, ChatCo, CodeCo, CloudCo, the PaymentsCo dashboard, the production database, and every third-party service holding Cypher Group information classified Internal or above.

It covers human user accounts, privileged administrative accounts, shared accounts and non-human service accounts and API keys.

3. Roles and responsibilities

Role	Responsibility
All personnel	Comply with the standards below; enrol in MFA; use the password manager
IT Operations Manager	Enforce the standards technically; run the quarterly privileged access review; maintain the shared account register
Chief Technology Officer	Own the policy; approve exceptions; hold the sealed break-glass credentials
Head of People and Operations	Ensure MFA enrolment is verified as part of onboarding

4. Policy statements

4.1 Password standards

4.1.1 Standard user account passwords **shall** be a minimum of **14 characters**.

4.1.2 Privileged and administrative account passwords **shall** be a minimum of **16 characters**.

4.1.3 Passphrases of four or more unrelated words are **recommended** as the easiest way to meet the length requirement.

4.1.4 Cypher Group **shall not** impose arbitrary composition rules requiring specific mixes of uppercase, numeric or special characters. Length and uniqueness are the controlling requirements.

4.1.5 Passwords **shall not** be reused across any two accounts, and **shall not** be reused from any personal account.

4.1.6 Where the platform supports it, candidate passwords **shall** be screened against known-breached password lists at the point they are set, and rejected if matched.

4.1.7 Passwords **shall not** be subject to routine scheduled expiry. Passwords **shall** be changed immediately where there is any indication of compromise, where the account has been shared, or where a person with knowledge of the credential has departed.

4.2 Password storage

4.2.1 All work credentials **shall** be stored in the Cypher Group-provided password manager.

4.2.2 Credentials **shall not** be stored in browser password stores, spreadsheets, documents, notes applications, ChatCo messages, Jira tickets or source code.

4.2.3 The password manager master password **shall** be a minimum of 16 characters, **shall** be unique, and **shall not** be recorded anywhere in electronic form.

4.2.4 Personnel **shall not** transmit a credential in plain text over any channel. Where a credential must be shared with an authorised person, it **shall** be shared through the password manager's secure sharing function.

4.3 Multi-factor authentication

4.3.1 Multi-factor authentication **shall** be enabled on **all** Cypher Group accounts, without exception, on the following systems as a minimum: OfficeCo, ChatCo, CodeCo, CloudCo, the PaymentsCo dashboard, and the production database administration interface.

4.3.2 MFA **shall** be enrolled within **one business day** of account creation. Access to Confidential or Restricted information **shall not** be granted before enrolment is verified.

4.3.3 **Privileged and administrative accounts shall use a phishing-resistant factor** — a FIDO2 or WebAuthn hardware security key, or a device-bound passkey. Time-based one-time codes are not sufficient for privileged accounts.

4.3.4 Standard user accounts **shall** use, in order of preference: a device-bound passkey, a hardware security key, or a time-based one-time password generated by an authenticator application.

4.3.5 **SMS text message and voice call shall not be used as an MFA factor**, because both are defeated by SIM-swap and interception attacks. Where a third-party service offers no alternative, use of SMS **shall** be recorded as a documented exception with an expiry date.

4.3.6 Personnel **shall** register at least two MFA factors where the platform permits, so that loss of a single device does not cause lockout.

4.3.7 Personnel **shall not** approve an MFA prompt they did not initiate. An unexpected prompt **shall** be reported under CGI-POL-005 within one hour, as it indicates the password is already compromised.

4.4 Privileged, shared and break-glass accounts

4.4.1 Personnel requiring administrative rights **shall** be issued a **separate administrative account**. Administrative accounts **shall not** be used for email, browsing or day-to-day work.

4.4.2 Shared accounts **shall** be avoided. Where a platform makes a shared account technically unavoidable, it **shall** be recorded in the shared account register with a named accountable owner, the credential **shall** be held only in the password manager, and the credential **shall** be rotated within **four hours** of any person with access departing or changing role.

4.4.3 The **CloudCo root account shall** be protected by a hardware MFA device, **shall not** be used for routine administration, and its credentials **shall** be sealed and held by the CTO. Any use of the root account **shall** generate an alert and **shall** be documented.

4.4.4 Break-glass emergency access credentials **shall** be sealed, stored in the password manager under CTO control, alerted on use, and rotated within 24 hours of any use.

4.5 Service accounts, API keys and secrets

4.5.1 Non-human service account credentials and API keys **shall** be rotated at least every **180 days**, and immediately on suspected compromise.

4.5.2 Secrets **shall not** be committed to any CodeCo repository. CodeCo secret scanning and push protection **shall** remain enabled on all Cypher Group repositories.

4.5.3 Where a secret is found to have been committed, it **shall** be treated as compromised, rotated immediately, and reported under CGI-POL-005 — removing the commit alone is not sufficient remediation.

4.5.4 Service accounts **shall** be granted the minimum permissions required and **shall** have a named human owner recorded.

4.6 Single sign-on and account lockout

4.6.1 Where a third-party service supports single sign-on through OfficeCo, Cypher Group **shall** enable it, so that account deprovisioning is centralised.

4.6.2 Accounts **shall** be temporarily locked for 15 minutes after 10 consecutive failed authentication attempts, and the event **shall** be logged. Permanent lockout **shall not** be used, as it enables denial-of-service against legitimate users.

5. Enforcement

5.1 Accounts not meeting the MFA requirement in section 4.3.1 **shall** have access to Confidential and Restricted systems suspended by the IT Operations Manager until the requirement is met.

5.2 Deliberate circumvention of authentication controls is a serious violation of CGI-POL-001 and may result in disciplinary action up to and including termination.

5.3 Exceptions **shall** be approved in writing by the CTO, recorded in the Exception Register with a compensating control and an expiry date not exceeding six months, and reviewed at expiry.

6. Review cadence

6.1 This policy **shall** be reviewed annually, and additionally following any authentication-related security incident or any material change to the identity platform.

6.2 The IT Operations Manager **shall** produce an **MFA coverage report quarterly**, listing every account and its MFA status, and **shall** provide it to the CTO. This report is retained as audit evidence.

7. Framework mapping

Policy section	ISO/IEC 27001:2022 Annex A	NIST CSF 2.0
4.1 Password standards	A.5.17	PR.AA-01
4.2 Password storage	A.5.17, A.8.24	PR.AA-01
4.3 Multi-factor authentication	A.8.5	PR.AA-03
4.4 Privileged and shared accounts	A.8.2, A.5.16	PR.AA-05
4.5 Service accounts and secrets	A.5.17, A.8.28	PR.AA-01, PR.PS-06
4.6 SSO and lockout	A.8.5	PR.AA-03

8. Definitions

Term	Definition
MFA	Multi-Factor Authentication: proving identity with two or more different types of evidence
Phishing-resistant factor	An authenticator cryptographically bound to the legitimate site, such as FIDO2, WebAuthn or a passkey, which cannot be relayed to a fake login page
TOTP	Time-based One-Time Password: the rotating six-digit code produced by an authenticator app
Privileged account	An account able to change security settings, access all data, or administer infrastructure
Break-glass account	An emergency account used only when normal access paths fail
Service account	A non-human account used by software to authenticate to another system

CGI-POL-003 — Onboarding and Offboarding Access Control Policy

Field	Value
Document ID	CGI-POL-003
Version	1.0
Classification	Internal
Policy owner	Priya Raman, Chief Technology Officer
Approved by	Jerry Gold, Chief Executive Officer
Approval date	01 September 2026
Effective date	15 September 2026
Review cadence	Annually, or upon significant change
Next review due	01 September 2027
Employee sign-off	Not required for all staff; required acknowledgement by all line managers

Version history

Version	Date	Author	Summary of change	Approved by
1.0	2026-09-01	O.S	Initial issue	Jerry Gold

1. Purpose

This policy governs the full lifecycle of a person's access to Cypher Group systems: how it is granted when they join, changed when their role changes, and removed when they leave. Its central objective is that **no individual retains access they no longer need**, and that departures never leave live accounts behind.

The lifecycle is referred to throughout as **JML — Joiner, Mover, Leaver**.

2. Scope

This policy applies to all personnel and to all Cypher Group systems and data, including OfficeCo, ChatCo, CodeCo, CloudCo, the PaymentsCo dashboard, the production database, the customer support platform and all approved third-party services.

It applies equally to employees, contractors, interns and any third party granted access to Cypher Group systems.

3. Roles and responsibilities

Role	Responsibility
Head of People and Operations	Notify IT of every joiner, mover and leaver; own the JML trigger process
Line manager	Raise and approve the access request; specify the role profile; confirm leaver timing
IT Operations Manager	Provision, modify and revoke access; maintain the access register; run access reviews
Chief Technology Officer	Approve privileged access and all exceptions; own this policy
System owner	Approve access to the system they own where it holds Restricted data
All personnel	Request access through the defined process only; never share access

4. Policy statements

4.1 Governing principles

4.1.1 Access **shall** be granted on the principle of **least privilege**: the minimum access required to perform the role, and no more.

4.1.2 Access **shall** be granted on the principle of **need to know**: possession of a general access level does not entitle an individual to data unrelated to their duties.

4.1.3 Access **shall** be granted **by role, not by individual request**, using the standard role profiles defined in section 4.2. Deviations from a role profile require CTO approval.

4.1.4 Access **shall** be time-bounded wherever the need is time-bounded. Access granted for a project **shall** carry an expiry date.

4.1.5 All access grants, changes and revocations **shall** be recorded in a ticket. An access change with no ticket is a policy violation, because it destroys the audit trail.

4.2 Standard role profiles

4.2.1 Cypher Group **shall** maintain a documented set of role profiles defining the default access bundle for each function.

Role profile	Default access granted	Access explicitly excluded
Engineering	OfficeCo, ChatCo, CodeCo (write, non-admin), CloudCo non-production, ticketing	CloudCo production, PaymentsCo, production database, billing
Engineering (on-call)	Engineering profile plus CloudCo production (time-bounded), production database read	PaymentsCo, billing, HR records
Customer Success	OfficeCo, ChatCo, support platform, customer account read	Source code, CloudCo, PaymentsCo, HR records
Sales	OfficeCo, ChatCo, CRM, customer account read	Source code, CloudCo, PaymentsCo, production database
Finance	OfficeCo, ChatCo, PaymentsCo dashboard, accounting platform	Source code, CloudCo, production database, HR records
People and Operations	OfficeCo, ChatCo, HR platform, payroll	Source code, CloudCo, PaymentsCo, customer data
Administrator	Named separate admin account with elevated rights on a specific system	Use for day-to-day work

4.2.2 Role profiles **shall** be reviewed at least annually by the CTO and the relevant department head.

4.3 Joiner — onboarding

4.3.1 The Head of People and Operations **shall** notify the IT Operations Manager of a confirmed start date **no later than five business days** before the start date.

4.3.2 The line manager **shall** raise an access request ticket specifying the role profile and any documented deviation, and **shall** approve it.

4.3.3 Accounts **shall not** be created more than **two business days** before the start date.

4.3.4 Access **shall** be provisioned within **one business day** of the approved ticket.

4.3.5 **Access shall not be activated until the individual has signed CGI-POL-001 (Acceptable Use Policy), CGI-POL-002, CGI-POL-004 and CGI-POL-005, and has completed MFA enrolment.** Sign-off is recorded in the Employee Policy Sign-off and Training Tracker.

4.3.6 New personnel **shall** complete security awareness induction within **10 business days** of their start date.

4.3.7 Access to systems holding **Restricted** data **shall** additionally require written approval from the relevant system owner and the CTO.

4.4 Mover — role change

4.4.1 The line manager **shall** raise a change ticket within **two business days** of a confirmed role change, secondment or internal transfer.

4.4.2 The change ticket **shall** state both the access to be **added** and the access to be **removed**.

4.4.3 Access no longer required **shall** be removed within **five business days** of the effective date of the change. Adding new access without removing redundant access, a condition known as **privilege creep**, is expressly prohibited.

4.4.4 Where an individual moves into a role requiring privileged access, the CTO **shall** approve, and a separate administrative account **shall** be issued in accordance with CGI-POL-002 section 4.4.

4.5 Leaver — offboarding

4.5.1 The Head of People and Operations **shall** notify the IT Operations Manager and the CTO **immediately** upon a resignation being tendered or a termination decision being made, and **shall** confirm the exact effective date and time of departure.

4.5.2 **All access shall be revoked within four hours of the effective termination time.** This includes OfficeCo, ChatCo, CodeCo, CloudCo, PaymentsCo, the production database, the support platform, all third-party services, and any physical access credential.

4.5.3 For **involuntary terminations**, access revocation **shall** be executed **simultaneously with**, and not after, the notification meeting.

4.5.4 Shared account credentials known to the departing individual **shall** be rotated within **four hours** of the effective termination time, in accordance with CGI-POL-002 section 4.4.2.

4.5.5 Any API key, deploy key, personal access token or service credential created by the departing individual **shall** be identified and rotated within **five business days**.

4.5.6 The departing individual's OfficeCo and ChatCo accounts **shall** be **suspended, not deleted**, for a minimum of **90 days**, so that records remain available for business continuity and any investigation. Deletion after 90 days requires line manager confirmation.

4.5.7 Ownership of files, documents and tickets held by the departing individual **shall** be transferred to their line manager before suspension.

4.5.8 Company devices, access cards and printed material **shall** be returned within **five business days** of the effective date.

4.5.9 The IT Operations Manager **shall** complete an offboarding checklist for every leaver and retain it as evidence. An offboarding is not closed until every line is evidenced.

4.6 Third-party and contractor access

4.6.1 Every third party granted access **shall** have a named Cypher Group employee sponsor who is accountable for that access.

4.6.2 Third-party access **shall** carry a mandatory expiry date not exceeding the contract end date, and in no case exceeding **12 months**.

4.6.3 Third-party access **shall** be reviewed **monthly** by the sponsor, who confirms it is still required.

4.6.4 Third parties **shall** meet the same authentication requirements as employees under CGI-POL-002.

4.7 Access reviews

4.7.1 A **privileged access review shall be performed quarterly**. The IT Operations Manager generates a listing of all accounts with administrative rights or access to Restricted data, reviews it with each relevant department head, and records approval or removal decisions in a ticket. Removals identified **shall** be completed within **five business days**.

4.7.2 A **general user access review shall be performed semi-annually** across all systems, following the same evidence requirements.

4.7.3 An **orphaned account check shall be performed monthly**: the IT Operations Manager reconciles the active account list against the current personnel list and investigates every discrepancy.

4.7.4 Evidence of every review — the listing reviewed, the reviewer, the date, the decisions and the completion of removals — **shall** be retained for a minimum of **two years**.

5. Enforcement

5.1 Granting access outside this process, including informally or verbally, is a policy violation and **shall** be reported to the CTO.

5.2 Failure by a line manager to notify a leaver in accordance with section 4.5.1 **shall** be escalated to the CEO, because it is the single control failure most likely to result in unauthorised access.

5.3 Exceptions **shall** be approved in writing by the CTO, recorded in the Exception Register with a compensating control, an accepting owner and an expiry date not exceeding 12 months.

6. Review cadence

6.1 This policy **shall** be reviewed annually, and additionally after any access-related incident, any change of identity provider, or any material change in headcount or organisational structure.

6.2 Metrics reported to the CTO quarterly: mean time to revoke access after departure, number of orphaned accounts found, percentage of access changes with a ticket, and percentage of access reviews completed on schedule.

7. Framework mapping

Policy section	ISO/IEC 27001:2022 Annex A	NIST CSF 2.0
4.1 Governing principles	A.5.15, A.8.2	PR.AA-05
4.2 Role profiles	A.5.15, A.5.18	PR.AA-05
4.3 Joiner	A.5.16, A.6.1, A.6.3	PR.AA-01, PR.AT-01
4.4 Mover	A.5.18	PR.AA-05
4.5 Leaver	A.5.11, A.6.5, A.5.18	PR.AA-05
4.6 Third-party access	A.5.19, A.5.20	GV.SC-04, PR.AA-05
4.7 Access reviews	A.5.18, A.8.2	PR.AA-05, DE.CM-03

8. Definitions

Term	Definition
JML	Joiner, Mover, Leaver: the three lifecycle events at which access must change
Provisioning	Creating and enabling a person's accounts and permissions
Deprovisioning	Disabling and removing a person's accounts and permissions

Term	Definition
Least privilege	Granting only the minimum access required, for the minimum time required
Need to know	Restricting information to those whose duties require it, regardless of clearance level
Privilege creep	The gradual accumulation of access rights as a person changes roles without old access being removed
Orphaned account	An active account with no current, identifiable owner
Role profile	A predefined bundle of access rights associated with a job function

CGI-POL-004 — Data Classification Policy

Field	Value
Document ID	CGI-POL-004
Version	1.0
Classification	Internal
Policy owner	Priya Raman, Chief Technology Officer
Approved by	Jerry Gold, Chief Executive Officer
Approval date	01 September 2026
Effective date	15 September 2026
Review cadence	Annually, or upon significant change
Next review due	01 September 2027
Employee sign-off	Required

Version history

Version	Date	Author	Summary of change	Approved by
1.0	2026-09-01	O.S	Initial issue. Four-tier model adopted.	Jerry Gold

1. Purpose

Not all information needs the same protection, and treating everything as highly sensitive is as ineffective as treating nothing as sensitive: it produces controls that people work around. This policy establishes a **four-tier classification model** and, critically, defines the **handling requirements** that follow from each tier.

This policy is the foundation on which the other policies in this pack rest. Access decisions under CGI-POL-003, encryption requirements, sharing rules and retention periods are all determined by the classification assigned here.

2. Scope

This policy applies to all Cypher Group information in any form — electronic files, databases, printed material, verbal communication and information held by third parties on Cypher Group's behalf — and to all personnel who create, handle, store, transmit or dispose of it.

3. Roles and responsibilities

Role	Responsibility
Chief Technology Officer	Own this policy; arbitrate classification disputes; approve reclassification of Restricted data
Data owners	Assign and maintain the classification of information in their domain; approve external sharing
All personnel	Apply the correct classification to information they create; handle information per its classification
IT Operations Manager	Implement the technical controls that enforce the handling matrix

3.1 Assigned data owners

Information domain	Data owner (role)	Data owner (simulated name)
Customer account data	Head of Customer Success	Amara Boateng
Payment metadata and financial records	Finance Manager	Jonas Keller
Source code and technical documentation	Chief Technology Officer	Priya Raman
Employee and recruitment records	Head of People and Operations	Sofia Lindqvist
Marketing and public communications	Chief Executive Officer	Jerry Gold

4. Policy statements

4.1 The four classification tiers

4.1.1 All Cypher Group information **shall** be classified into exactly one of four tiers.

Tier	Definition	Impact if disclosed without authorisation	Cypher Group examples
Public	Information approved for release to anyone, including outside the company	No adverse impact	Marketing website copy, published pricing, job advertisements, public API documentation, press releases
Internal	Information intended for personnel and approved contractors, not for public release	Minor adverse impact; embarrassment or minor competitive disadvantage	Team wiki pages, org chart, internal roadmap, meeting notes, most ChatCo channels, this policy pack
Confidential	Information whose disclosure would cause material harm to Cypher Group, a customer or an individual	Material harm; contractual breach, lost customers, regulatory attention	Customer account data, application source code, customer contracts, employee records, support tickets, unreleased product designs
Restricted	The most sensitive information, disclosure of which would cause severe harm; access is limited to a named list	Severe harm; existential business or regulatory consequence	PaymentsCo payment metadata, production database credentials, CloudCo root credentials, API keys and secrets, security incident records, bulk exports of customer personal data

4.1.2 **Default classification.** Information that has not been explicitly classified **shall** be treated as **Internal**. Personnel **shall not** treat unlabelled information as Public.

4.1.3 **Aggregation.** A collection of lower-tier records **may** warrant a higher classification than any individual record. A single customer's contact detail is Confidential; a full export of all 200 customer records is **Restricted**.

4.1.4 **Payment data scope.** Cypher Group **does not store payment card numbers**. Card data is held by PaymentsCo. Cypher Group holds **payment metadata** — amounts, dates, transaction identifiers and the customer account they relate to — which is classified **Restricted**.

4.2 Handling matrix

4.2.1 Information **shall** be handled in accordance with the following matrix.

Handling requirement	Public	Internal	Confidential	Restricted
Encryption at rest	Not required	Recommended	Required	Required
Encryption in transit	Recommended	Required	Required	Required
Approved storage locations	Any approved system	OfficeCo, ChatCo, approved SaaS	OfficeCo with restricted sharing, CodeCo private repositories, CloudCo production	Named approved systems only, listed by the data owner
Access basis	Open	All personnel	Role profile plus business need	Named individual list, approved by data owner and CTO
Internal sharing	Unrestricted	Unrestricted within personnel	Business need only	Named list only; no forwarding
External sharing	Permitted	Line manager approval	Data owner approval plus signed NDA or contract	Data owner plus CTO approval plus contract with security terms
Permitted transmission channels	Any	Company email, ChatCo	Company email, ChatCo, approved file sharing with link expiry	Approved file sharing with expiry and named recipients only
Removable media	Permitted	Discouraged	CTO approval required	Prohibited
Use in unapproved AI tools	Permitted	Prohibited	Prohibited	Prohibited
Printing	Permitted	Permitted	Permitted, must not be left unattended	Prohibited without CTO approval
Minimum retention	None	1 year	Per contract, minimum 3 years	Per contract or legal obligation

Handling requirement	Public	Internal	Confidential	Restricted
Maximum retention	Indefinite	3 years	7 years	Minimum necessary, documented by data owner
Disposal method	Standard delete	Standard delete	Secure delete, action logged	Cryptographic erasure or certified destruction, certificate retained
Incident reporting on loss	Not required	Report within 24 hours	Report within 1 hour	Report immediately, SEV1 or SEV2

4.3 Labelling

4.3.1 Documents classified **Confidential** or **Restricted shall** carry the classification in the document header or on the first page.

4.3.2 ChatCo channels carrying Confidential or Restricted information **shall** be private and **shall** state the classification in the channel description.

4.3.3 Email containing Restricted information **shall** carry the classification in the subject line.

4.3.4 Absence of a label does not lower the handling requirement; the information's actual sensitivity governs.

4.4 Reclassification and declassification

4.4.1 The data owner **may** reclassify information when its sensitivity changes — for example, an unreleased product design becomes **Public** on launch day.

4.4.2 Reclassification of **Restricted** information downward **shall** require CTO approval and **shall** be recorded.

4.4.3 Reclassification does not retrospectively authorise a disclosure that breached the previous classification.

4.5 Personal data

4.5.1 Cypher Group processes a limited amount of **PII (Personally Identifiable Information)**, principally customer contact details and employee records. All PII **shall** be classified **Confidential** as a minimum, and **Restricted** where held in bulk.

4.5.2 Personal data **shall** be collected and retained only where there is a defined business purpose, and **shall** be deleted when that purpose ends, in accordance with the retention limits in section 4.2.

4.5.3 Where a third party processes personal data on Cypher Group's behalf, a written **DPA (Data Processing Agreement) shall** be in place before processing begins.

4.5.4 Where the **GDPR (General Data Protection Regulation)** applies to a given customer or employee relationship, Cypher Group acts as a **processor** in respect of customer data and a **controller** in respect of employee data. Notification obligations arising from a personal data breach are addressed in CGI-POL-005.

4.5.5 Requests from individuals to access, correct or delete their personal data **shall** be routed to the Head of People and Operations for employee data, or the Head of Customer Success for customer data, and **shall** be acknowledged within five business days.

5. Enforcement

5.1 Handling information below its required classification level is a policy violation and **shall** be reported under CGI-POL-005.

5.2 Deliberate mislabelling of information to avoid handling requirements is a serious violation and may result in disciplinary action up to and including termination.

5.3 Personnel who identify information that is misclassified **shall** report it to the data owner. Reporting in good faith attracts no penalty.

5.4 Exceptions **shall** be approved in writing by the CTO and the relevant data owner, recorded in the Exception Register with a compensating control and an expiry date not exceeding 12 months.

6. Review cadence

6.1 This policy **shall** be reviewed annually, and additionally upon any new customer contractual data commitment, any new category of data being processed, or any change in applicable data protection law.

6.2 Data owners **shall** confirm annually that the classification of information in their domain remains correct, and this confirmation **shall** be retained as evidence.

7. Framework mapping

Policy section	ISO/IEC 27001:2022 Annex A	NIST CSF 2.0
4.1 Classification tiers	A.5.12	ID.AM-07
4.2 Handling matrix	A.5.13, A.5.14, A.8.10, A.8.11, A.8.24	PR.DS-01, PR.DS-02
4.3 Labelling	A.5.13	ID.AM-07
4.4 Reclassification	A.5.12	ID.AM-07
4.5 Personal data	A.5.34, A.5.33	GV.PO-01, PR.DS-01
Retention and disposal	A.5.33, A.8.10	PR.DS-01

8. Definitions

Term	Definition
Classification	The assignment of information to a defined sensitivity tier
Data owner	The accountable individual for a category of information, who approves its classification and its sharing
PII	Personally Identifiable Information: data that identifies or can identify a living individual
Payment metadata	Data about a transaction — amount, date, identifier, associated account — excluding card numbers
Aggregation	The principle that a collection of records may be more sensitive than any single record
DPA	Data Processing Agreement: the contract required where a third party processes personal data on your behalf
Controller and processor	Under GDPR, the party deciding why and how personal data is processed, and the party processing it on their instructions
Cryptographic erasure	Rendering data unrecoverable by destroying the encryption key rather than the data itself

CGI-POL-005 — Incident Reporting Policy

Field	Value
Document ID	CGI-POL-005
Version	1.0
Classification	Internal
Policy owner	Priya Raman, Chief Technology Officer
Approved by	Jerry Gold, Chief Executive Officer
Approval date	01 September 2026
Effective date	15 September 2026
Review cadence	Annually, and after every SEV1 or SEV2 incident
Next review due	01 September 2027
Employee sign-off	Required

Version history

Version	Date	Author	Summary of change	Approved by
1.0	2026-09-01	O.S	Initial issue. Aligned to NIST SP 800-61 Rev. 3 and NIST CSF 2.0.	Jerry Gold

1. Purpose

The single largest factor in how badly a security incident hurts a company is **how quickly it is reported**. This policy tells every person at Cypher Group what to report, who to tell, how fast, and what happens next — and it commits the company to treating good-faith reporting as helpful rather than punishable.

The incident response approach is aligned to **NIST SP 800-61 Rev. 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management** (published April 2025), which frames incident response around the NIST Cybersecurity Framework 2.0 functions — Govern, Identify, Protect, Detect, Respond and Recover — rather than a standalone lifecycle.

2. Scope

This policy applies to all personnel and to all suspected or confirmed security events affecting Cypher Group systems, information, customers or personnel, including events originating at a third-party supplier.

Reporting obligations under this policy apply **24 hours a day**, including outside working hours.

3. Definitions — know the difference

Term	Definition	Example at Cypher Group
Security event	Any observable occurrence that may have security relevance	A failed login alert; an unexpected MFA prompt
Security incident	An event that actually or potentially compromises confidentiality, integrity or availability	An employee's Google account is accessed from an unrecognised country
Personal data breach	An incident leading to accidental or unlawful destruction, loss, alteration, or unauthorised disclosure of, or access to, personal data	Customer contact export emailed to the wrong recipient
Near miss	An event that could have become an incident but did not	An employee spots and reports a phishing email before clicking

> **Every breach is an incident. Not every incident is a breach.** Getting this distinction right matters, because breach status triggers external legal and contractual notification obligations that an ordinary incident does not.

4. Roles and responsibilities

Role	Responsibility
All personnel	Report promptly; preserve evidence; do not investigate independently
Incident Commander (default: CTO)	Declares the incident and its severity; directs the response; decides on escalation
Technical Lead (IT Operations Manager)	Performs containment, eradication and recovery actions
Communications Lead (Head of Customer Success)	Owns all customer and external communication
Legal and Privacy Lead (CEO, with external counsel)	Determines regulatory notification obligations
Scribe (assigned at declaration)	Maintains the incident timeline and decision log

5. Policy statements

5.1 What must be reported

5.1.1 Personnel **shall** report any of the following immediately:

- Clicking a link, opening an attachment, or entering credentials in response to a suspected phishing message
- Loss or theft of any device used for Cypher Group work
- An MFA prompt the individual did not initiate
- A notification that an account has been accessed from an unfamiliar location or device
- Accidental disclosure of information to the wrong recipient, including a misaddressed email or a wrongly shared file
- Discovery of a credential, API key or secret in source code, a document or a message
- Unexpected system behaviour suggesting compromise, such as unexplained changes, missing data or new accounts
- Notification from a supplier, customer or external party of a security issue affecting Cypher Group
- Any suspected violation of CGI-POL-001 to CGI-POL-004
- Any near miss

5.1.2 **If in doubt, report.** Personnel are never penalised for reporting something that turns out to be benign.

5.2 How and when to report

5.2.1 Reports **shall** be made through one of the following channels, whichever is fastest:

Channel	Detail	Availability
ChatCo	The private channel `#security-incidents`	24 hours, monitored with alerting
Email	`security@cyphergroup.example`	24 hours, alerts to the CTO
Direct	Priya Raman, CTO, or Tomas Whitfield, IT Operations Manager	24 hours for urgent matters

5.2.2 Reports **shall** be made **immediately on becoming aware**, and in any case within **one hour**.

5.2.3 A report **shall** include, as far as known: what happened, when it was noticed, which systems or data are involved, what the reporter has already done, and how the reporter can be contacted.

5.2.4 An incomplete report made quickly is preferred to a complete report made slowly. Personnel **shall not** delay reporting in order to gather more detail.

5.3 What personnel must not do

5.3.1 Personnel **shall not** attempt to investigate, remediate or "test" a suspected incident themselves.

5.3.2 Personnel **shall not** delete emails, files, messages or logs relating to a suspected incident. Evidence preservation is essential.

5.3.3 Personnel **shall not** discuss a suspected or confirmed incident with anyone outside the response team, including customers, on social media, or in public ChatCo channels, until the Communications Lead authorises it.

5.3.4 Personnel **shall not** contact the suspected attacker or reply to an extortion demand.

5.4 Severity classification and response targets

5.4.1 The Incident Commander **shall** assign a severity within **30 minutes** of an incident being declared.

Severity	Definition	Examples	Target acknowledgement	Target containment	Escalation
SEV1	Confirmed compromise of production, customer data or Restricted information; or full service outage	Production database accessed by an unauthorised party; ransomware; bulk customer data exfiltration	15 minutes	4 hours	CEO and Board immediately
SEV2	Probable compromise with contained scope; or significant service degradation	Single employee account confirmed compromised; customer data emailed to wrong recipient	30 minutes	8 hours	CEO within 1 hour
SEV3	Security issue with limited impact and no confirmed data exposure	Phishing link clicked with no credentials entered; lost device with encryption enabled	4 hours	2 business days	CTO
SEV4	Minor issue, near miss, or policy violation with no impact	Reported phishing email, not clicked; misconfigured ChatCo channel corrected	1 business day	5 business days	IT Operations Manager

5.5 Response process

5.5.1 The response **shall** follow this sequence, with the Scribe recording a timestamped entry at each stage:

Stage	What happens	CSF 2.0 function
Detect and report	Event observed and reported through a channel in 5.2.1	Detect
Triage and declare	Incident Commander confirms, assigns severity, assembles the team	Respond
Contain	Stop the harm spreading: disable accounts, rotate credentials, isolate systems	Respond
Analyse	Determine scope, root cause, and what data or systems were affected	Respond
Eradicate	Remove the cause: close the vulnerability, remove attacker access	Respond
Recover	Restore normal service and verify integrity	Recover
Notify	Execute customer, contractual and regulatory notifications per 5.6	Respond
Review	Blameless post-incident review and corrective actions per 5.7	Govern, Identify

5.5.2 Containment **shall** take precedence over evidence preservation where there is an active, ongoing compromise. The Incident Commander makes that call and records the reasoning.

5.6 External notification

5.6.1 All external communication **shall** be issued by the Communications Lead. No other person is authorised to communicate externally about an incident.

5.6.2 **Customer notification.** Where an incident affects customer data or service, affected customers **shall** be notified in accordance with their contractual terms. Where no contractual term specifies otherwise, Cypher Group **shall** notify affected customers within **72 hours** of confirming impact.

5.6.3 **Regulatory notification.** Where the incident constitutes a personal data breach and the GDPR applies, notification to the relevant supervisory authority **shall** be made **without undue delay and where feasible within 72 hours** of

becoming aware, unless the breach is unlikely to result in a risk to individuals. Where the breach is likely to result in a **high risk** to individuals, those individuals **shall** also be notified without undue delay. The Legal and Privacy Lead, with external counsel, makes this determination — **not** the engineer who found the issue.

5.6.4 The 72-hour clock starts at the point of **awareness**, not at the point of full understanding. Notification **shall not** be delayed to complete the investigation; a partial notification followed by an update is the expected approach.

5.7 Post-incident review

5.7.1 A post-incident review **shall** be held within **five business days** for every SEV1 and SEV2 incident, and within 15 business days for SEV3.

5.7.2 The review **shall** be **blameless**. Its purpose is to identify the systemic conditions that allowed the incident, not to identify a person to hold responsible. A review that produces "the employee should have been more careful" as its root cause has failed.

5.7.3 The review **shall** produce: a timeline, a root cause analysis, a list of corrective actions with named owners and due dates, and an assessment of whether any policy in this pack requires amendment.

5.7.4 Corrective actions **shall** be tracked to completion and verified by the CTO.

5.7.5 An incident register **shall** be maintained recording every incident, its severity, dates, root cause and closure status, and **shall** be retained for a minimum of **three years**.

6. Enforcement and non-retaliation

6.1 **Non-retaliation.** Cypher Group **shall not** take disciplinary action against any individual for reporting a security incident in good faith, including where that individual caused it. This commitment is deliberate and is more valuable to the company than any deterrent effect discipline might have, because concealed incidents are far more damaging than reported ones.

6.2 Failure to report a known incident, deliberate concealment, or obstruction of an investigation **is** a disciplinary matter and may result in action up to and including termination.

6.3 The protection in 6.1 does not extend to deliberate malicious acts.

7. Review cadence

7.1 This policy **shall** be reviewed annually, and additionally after every SEV1 or SEV2 incident, and after every incident response exercise.

7.2 A **tabletop incident response exercise shall be conducted at least annually**, and its findings fed into the next review of this policy.

8. Framework mapping

Policy section	ISO/IEC 27001:2022 Annex A	NIST CSF 2.0
5.1 What to report	A.6.8	DE.AE-02, RS.MA-01
5.2 How and when	A.5.24, A.6.8	RS.MA-01
5.3 Evidence preservation	A.5.28	RS.AN-07
5.4 Severity classification	A.5.25	RS.MA-03
5.5 Response process	A.5.26	RS.MA, RS.AN, RC.RP
5.6 External notification	A.5.24, A.5.34, A.6.8	RS.CO-02, RS.CO-03
5.7 Post-incident review	A.5.27	ID.IM-03, ID.IM-04
7.2 Tabletop exercise	A.5.24, A.5.30	ID.IM-02

Appendix A — Consolidated framework coverage

This pack contributes to the following control areas. This mapping is what allows one set of policies to support multiple compliance programmes simultaneously.

Framework	Coverage provided by this pack
ISO/IEC 27001:2022 Annex A	38 controls addressed in whole or in part, principally across A.5 Organisational and A.8 Technological themes
NIST CSF 2.0	Contributes to GOVERN (GV.PO), PROTECT (PR.AA, PR.DS, PR.AT, PR.PS), DETECT (DE.CM, DE.AE), RESPOND (RS.MA, RS.CO, RS.AN) and RECOVER (RC.RP)
SOC 2 Trust Services Criteria	Supports CC1 Control Environment, CC2 Communication, CC5 Control Activities, CC6 Logical Access, CC7 System Operations, CC9 Risk Mitigation
GDPR	Supports Article 32 security of processing, Articles 33 and 34 breach notification, Article 5(1)(f) integrity and confidentiality

Note on coverage claims. These mappings are the author's own analysis for a simulated scenario. They have not been reviewed by a certification body or a CPA firm, and no certification or attestation is claimed or implied.

Appendix B — Exception Register (populated example)

Exception ID	Policy	Requirement excepted	Business justification	Compensating control	Approved by	Approval date	Expiry date	Status
EXC-001	CGI-POL-002	4.3.5 prohibition on SMS as an MFA factor	Legacy billing portal supports SMS only; migration planned Q1 2027	Access limited to two named finance users; login alerting enabled; monthly access review	Priya Ramanan	2026-09-03	2027-03-03	Open
EXC-002	CGI-POL-003	4.5.2 four-hour access revocation	Contractor engaged through an agency portal Cypher does not administer directly	Agency contractually required to revoke within 24 hours and confirm in writing; sponsor verifies	Priya Ramanan	2026-09-03	2027-09-03	Open
EXC-003	CGI-POL-004	4.2 prohibition on Restricted data (payment metadata) on removable media	Annual financial audit requires an encrypted drive handover to external auditors	AES-256 encrypted drive; courier tracked; drive returned and wiped within 10 business days; logged	Priya Ramanan	2026-09-04	2026-12-31	Open

Appendix C — Policy Register

Policy ID	Policy name	Version	Owner	Approver	Effective	Last review	Next review	Sign-off required	Percentage acknowledged	Location
CGI-POL-001	Acceptable Use Policy	1.0	Head of People and Operations	CEO	2026-09-15	2026-09-01	2027-09-01	Yes	60	Internal wiki, Policies
CGI-POL-002	Password and MFA Policy	1.0	CTO	CEO	2026-09-15	2026-09-01	2027-09-01	Yes	60	Internal wiki, Policies
CGI-POL-003	Onboarding and Offboarding Access Control Policy	1.0	CTO	CEO	2026-09-15	2026-09-01	2027-09-01	Managers only	100	Internal wiki, Policies
CGI-POL-004	Data Classification Policy	1.0	CTO	CEO	2026-09-15	2026-09-01	2027-09-01	Yes	60	Internal wiki, Policies
CGI-POL-005	Incident Reporting Policy	1.0	CTO	CEO	2026-09-15	2026-09-01	2027-09-01	Yes	60	Internal wiki, Policies

Acknowledgement percentages are taken from CGI-TRK-001 as at 05 September 2026, which records a five-person illustrative sample.

END OF PACK — CGI-POL-001 to CGI-POL-005, version 1.0

Prepared by O.S · Portfolio project 01.